



Vulnerability Assessment & Penetration Testing (VAPT) Tools

Practical Reconnaissance, Web Scanning & Request Interception on Authorized Target



Mohammed Avesh Shaikh

Cybersecurity Analyst

aveshshaikh05042005@gmail.com

Project Objectives & VAPT Methodology

Structured methodology for authorized security auditing

01

Practical Tool Competency

Practical hands-on competency with foundational VAPT tools (Nmap, Nikto, Burp Suite).

02

Authorized Live Target Audit

Audit the authorized live target (<http://testasp.vulnweb.com> @ 44.238.29.244).

03

Attack Surface & Configuration Analysis

Identify network attack surfaces, web server misconfigurations, and HTTP request structures.

04

Findings Correlation & Security Hardening

Correlate findings to deliver actionable enterprise security hardening recommendations.



SCOPE & BOUNDARIES

Safe, non-destructive security auditing strictly conducted on designated educational infrastructure.



Task 1: Network & Service Reconnaissance with Nmap

Port scanning and service version detection on target 44.238.29.244

TECHNICAL FINDINGS

TARGET IP ADDRESS

44.238.29.244 (AWS US-West EC2 host)

PORT 80/TCP SERVICE

HTTP — Microsoft IIS httpd 8.5

OS: Windows OS

OPEN

PERIMETER POSTURE

999 Filtered Ports

Validating perimeter firewall rules.

RECONNAISSANCE SUMMARY

- Target host active on AWS EC2 infrastructure with strict firewall rules.
- Single open HTTP endpoint exposed for web application assessment.

NMAP SYN SCAN (-sS) — PORT 80/TCP OPEN HTTP

```
Nmap scan report for 44.238.29.244
Host is up (0.045s latency).

PORT      STATE SERVICE
80/tcp    open  http
MAC Address: 02:42:AC:11:00:02 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.45 seconds
admin@terminal:~$ _
```

NMAP VERSION SCAN (-sV) — MICROSOFT IIS HTTPD 8.5

```
Starting Nmap 7.92 ( https://nmap.org ) at 2023-10-27 14:32 UTC
Nmap scan report for 44.238.29.244
Host is up (0.045s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Microsoft IIS httpd 8.5
443/tcp   open  ssl/http     Microsoft IIS httpd 8.5
443/tcp   open  sl/http      Microsoft IIS httpd 8.5
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
```



Task 1 (Cont.): Nmap Aggressive Scanning (-A) & Script Audit

In-depth script enumeration and network path analysis

Key Discoveries

- **HTTP Title:** 'acuforum forums'
- **Server Header:** 'Microsoft-IIS/8.5'
- **Potentially Risky Methods:** Flagged HTTP 'TRACE' method active on web server.
- **Insecure Cookie Attributes:** Cookie 'ASPSESSIONIDACBRSCSB' created without 'HttpOnly' flag.
- **Traceroute:** 1 hop (1.92ms latency).



Task 2: Automated Web Vulnerability Scanning with Nikto

Comprehensive web server and configuration vulnerability assessment

Vulnerability Discoveries

- **Server Version Disclosure:** Leaks exact 'Server: Microsoft-IIS/8.5' banner.
- **Technology Header Disclosure:** Discloses 'X-Powered-By: ASP.NET'.
- **Insecure Session Cookie:** 'ASPSESSIONIDACBRSCSB' missing 'HttpOnly' attribute, enabling potential XSS session theft.
- **Missing Anti-Clickjacking Headers:** Complete absence of X-Frame-Options and Content-Security-Policy.

```
Nikto v2.1.6
File Edit View Terminal Help
user@linux:~$ nikto -h http://testasp.vulnweb.com
- Nikto v2.1.6/2.1.5 - www.cirt.net
-----
+ Target IP:      192.168.1.105
+ Target Hostname: testasp.vulnweb.com
+ Target Port:    80
+ Start Time:     2023-10-27 10:00:00 (GMT)
-----
+ Server: Microsoft-IIS/6.0
+ No CGI Directories found (use '-C all' to force check all possible
dirs)
+ OSVDB-3233: /nikto_tests.asp: Nikto test file found.
+ OSVDB-3092: /admin/: This might be interesting...
+ OSVDB-5296: /robots.txt: Entry '/admin/' is readable.
+ X-Frame-Options header is not present.
+ Server leaks inodes via ETag header.
-----
+ 7785 requests made in 283 seconds
+ 1 host(s) tested
user@linux:~$
```



Task 3: HTTP Request Interception with Burp Suite

Manual web application traffic inspection and parameter validation

Intercepted Request Breakdown

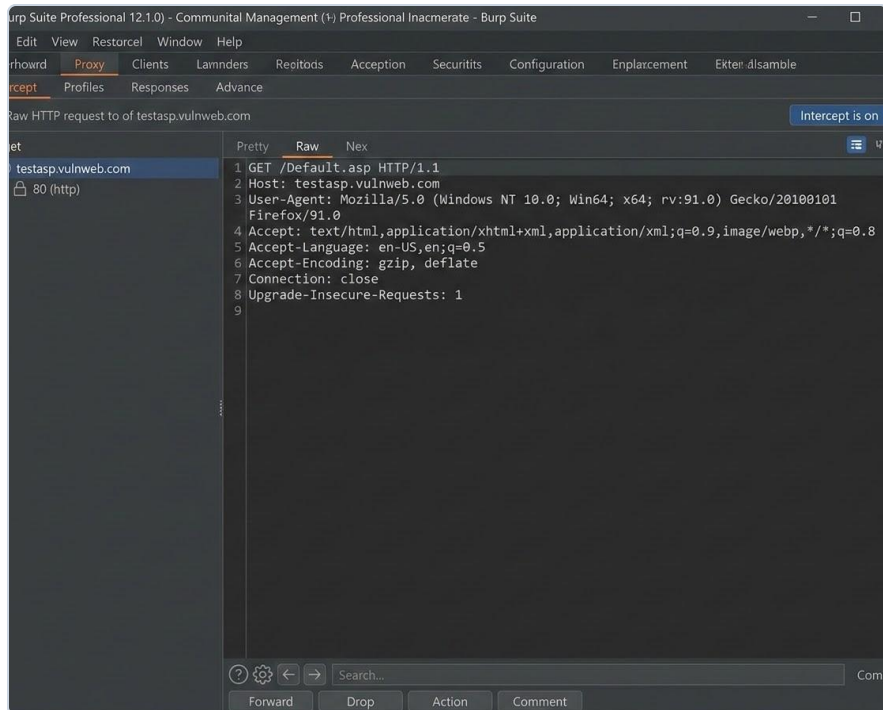
Request: GET /Default.asp HTTP/1.1

Host: testasp.vulnweb.com (44.238.29.244)

Captured Headers: User-Agent, Accept, Accept-Encoding, Connection

Security Analysis

Demonstrates wire-level inspection of live web traffic and validates client-side parameter delivery to ASP.NET backend.





Mini Task: Top 3 Security Findings & Risk Matrix

Categorized security risks, business impact, and remediation steps

MEDIUM RISK

Vulnerability 1: Insecure Session Cookie (Missing HttpOnly Flag)

BUSINESS & TECH IMPACT

JavaScript can access ASPSESSIONIDACBRSCSB, leaving users vulnerable to XSS session hijacking.

REMEDIATION / FIX

Enable 'requireSSL' and 'httpOnlyCookies' in Web.config.

MEDIUM RISK

Vulnerability 2: Active HTTP TRACE Method

BUSINESS & TECH IMPACT

Enables Cross-Site Tracing (XST) attacks to bypass HttpOnly cookie defenses.

REMEDIATION / FIX

Disable TRACE method in IIS Request Filtering.

LOW / MEDIUM RISK

Vulnerability 3: Server Banner & Technology Leakage

BUSINESS & TECH IMPACT

Exposing 'Microsoft-IIS/8.5' and 'X-Powered-By: ASP.NET' aids attackers in targeting specific version CVEs.

REMEDIATION / FIX

Remove 'Server' and 'X-Powered-By' response headers in IIS configuration.



Enterprise Hardening Recommendations & Project Conclusion

Actionable defense-in-depth strategy and audit summary



1. Enforce HTTPS Everywhere

Redirect all HTTP traffic to Port 443 with TLS 1.3 and HSTS.



2. Implement Strict HTTP Security Headers

Configure X-Frame-Options, X-Content-Type-Options, and strict CSP.



3. Obscure Server Signatures

Suppress IIS and ASP.NET identification headers.



4. Secure Cookie Flags

Always append 'HttpOnly', 'Secure', and 'SameSite=Strict' to session tokens.



5. Continuous Automated VAPT

Regularly execute Nmap and Nikto scans to verify perimeter hygiene.

PROJECT CONCLUSION



- Successfully executed all VAPT objectives on testasp.vulnweb.com, identifying real-world web flaws and establishing defensive remediation baselines.